

OWASP Use Cases

Estimated time needed: 5 minutes

Learning Objectives

After completing this reading, you'll be able to:

- List OWASP standards
- Describe the purpose of each standard

OWASP standards

The Open Web Application Security Project (OWASP) is a nonprofit organization focused on making software more secure. It started on December 1, 2001, and became an official nonprofit in the U.S. on April 21, 2004. OWASP works by offering free resources like code, guides, and standards to help with safe software creation and use. It has over 250 local groups worldwide and many members who share knowledge and tools for secure software development.

OWASP also holds educational events to teach people about application security. Its resources, like projects, tools, documents, and forums, are free, making it easy for anyone interested in software security to learn and help make the digital world safer.

OWASP has established various standards and resources to improve the security of software and web applications. Among these, the most recognized include:

- OWASP Top 10
- OWASP Application Security Verification Standard (ASVS)
- Mobile Application Security Verification Standard (MASVS)
- OWASP Software Assurance Maturity Model (SAMM)
- OWASP Testing Guide
- OWASP Cheat Sheet Series

OWASP Top 10

The OWASP Top 10 is a widely recognized document that outlines the ten most critical web application security risks, serving as a guideline for developers and security professionals to understand and mitigate prevalent vulnerabilities. It covers risks from broken access control to injection attacks, cryptographic failures, and security misconfigurations. The list is updated periodically to reflect the evolving threat landscape. It emphasizes the importance of secure coding practices, regular updates to software components, and proactive security measures to protect web applications from exploitation. Understanding the OWASP Top 10 is essential for anyone involved in web application development or security, as it provides a foundation for building and maintaining secure software systems.

OWASP ASVS

The OWASP Application Security Verification Standard (ASVS) is a framework for assessing the security of web applications and services. It provides comprehensive security requirements and controls that guide developers and organizations in creating and maintaining secure applications. The ASVS categorizes these requirements into different levels of assurance tailored to the application's risk profile and covers a wide range of security topics, from authentication and session management to access control and cryptographic practices. By following the ASVS guidelines, organizations can achieve a consistent and comprehensive strategy for application security, which is crucial for IT and security experts focused on protecting their web applications from potential risks.

OWASP MASVS

The Open Web Application Security Project Mobile Application Security Verification Standard (OWASP MASVS) is a framework to establish a security baseline for mobile applications. It provides a comprehensive set of security requirements that developers and testers can follow to ensure their mobile applications are secure against common threats and vulnerabilities. The MASVS is structured into different levels of security rigor, making it adaptable to various risk scenarios and application types, from those dealing with highly sensitive information to less critical applications. This standard aims to guide the secure development and testing of mobile apps, ensuring that security is not an afterthought but an integral part of the app development lifecycle.

OWASP SAMM

The OWASP Software Assurance Maturity Model (SAMM) is an open framework designed to help organizations formulate and implement a strategy for software security that integrates easily into their existing Software Development Lifecycle (SDLC). It provides a structured path for improving the security posture of software practices, regardless of the organization's size or the software they use. SAMM offers a comprehensive set of security practices across various business functions, structured into maturity levels that guide organizations from initial, ad hoc practices to a mature, repeatable, and measurable software security program. This model facilitates the entire software lifecycle and is adaptable to various technologies and processes, serving as a flexible resource for ongoing enhancement in software assurance.

OWASP Testing Guide

The OWASP Testing Guide is a comprehensive manual that provides a framework for the security testing of web applications and services. It is designed to help organizations understand and implement a robust testing program, offering a broad view of the elements required for a comprehensive web application security program. The guide results from collaborative efforts by cybersecurity professionals and volunteers, detailing best practices for penetration testing and other security assessments. It highlights a repeatable scientific methodology for testing, ensuring that web applications undergo an exhaustive and systematic evaluation of security vulnerabilities.

OWASP Cheat Sheet Series

The OWASP Cheat Sheet Series is a collection of concise, high-value documents on various application security topics created by seasoned security professionals. These cheat sheets are designed to provide quick, practical security guidance in an easily digestible format, covering a wide range of subjects from secure coding and injection prevention to authentication best practices and cryptographic standards. They are a go-to resource for developers and security practitioners looking to bolster their application security knowledge and implement robust security measures efficiently. The series contributes to OWASP's dedication to enhancing software security via open-source materials, aiding professionals in keeping updated with the newest security tactics.

Conclusion

These standards and resources are designed to be applied by anyone involved in the web application lifecycle, whether coding, designing, or maintaining these applications, to improve their security posture and mitigate risks.

Author

Dee Dee Collette



Skills Network